Governance for GenAI

by Christopher Nett

Connect with me!

Get discounted courses, updates and industry insights

My Website

Azure Newsletter

Cybersecurity Newsletter

Social Media

LinkedIn

X

Bluesky

Threads

What is a Large Language Model (LLM)?

LLMs predict the probability of the next token given previous context.

Question:
How do you feel?

I		am		happy	
I	0.21	am	0.21	happy	0.25
You	0.19	was	0.19	there	0.22
We	0.18	think	0.18	good	0.17
Well	0.09	want	0.09	excited	0.08
Ok	0.05	Do	0.05	nervous	0.02

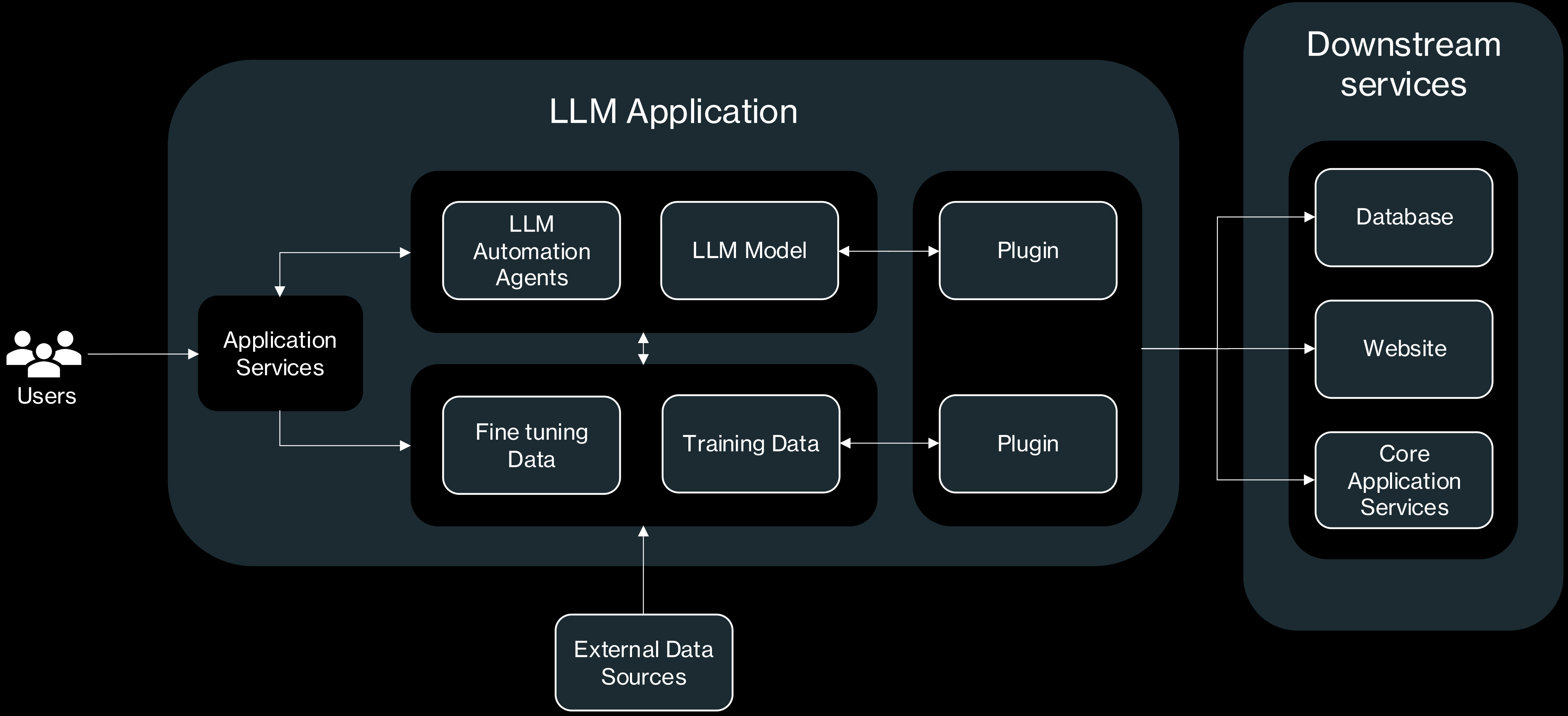
Source: [Language Modeling (lena-voita.github.io)]

What is a prompt?

- A prompt in Language Model (LLM) context refers to the input or query provided to the model to generate a desired response or output
- Prompts serve as the means of interacting with LLMs, instructing them to perform specific tasks or generate text based on user input
- Prompts can vary in format, including natural language questions, incomplete sentences, or structured commands, depending on the LLM's capabilities
- Crafting effective prompts is crucial for obtaining desired results and ensuring the LLM's responses are accurate, coherent, and contextually appropriate.

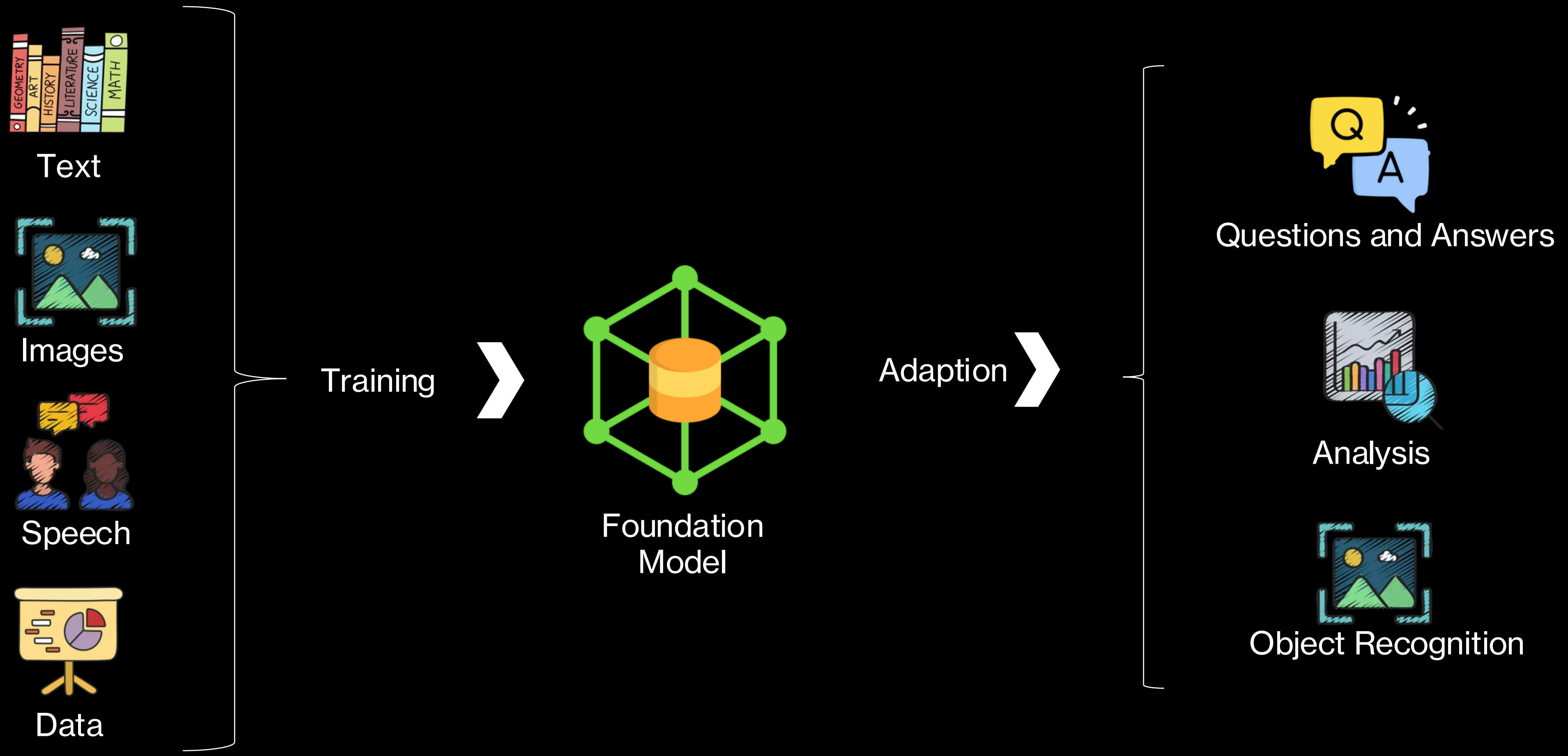
Source: OWASP Top 10 for Large Language Model Applications | OWASP Foundation

LLM Architecture



Source: OWASP Top 10 for Large Language Model Applications | OWASP Foundation

AI Models



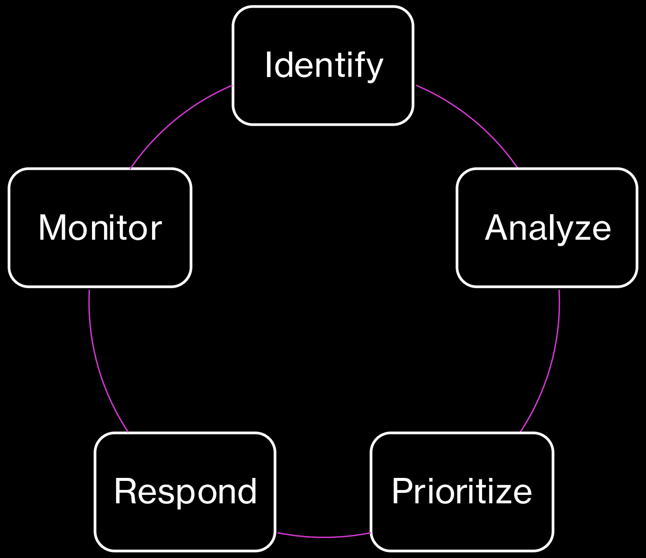
Christopher Nett

Corporate Governance

- “System of rules, practices, and processes by which a firm is directed and controlled”
- Implemented through enterprise risk management, internal controls, and corporate social responsibility
- ERM acts as a governance mechanism of corporate governance because it enables the enterprise to conduct risk aware decisions

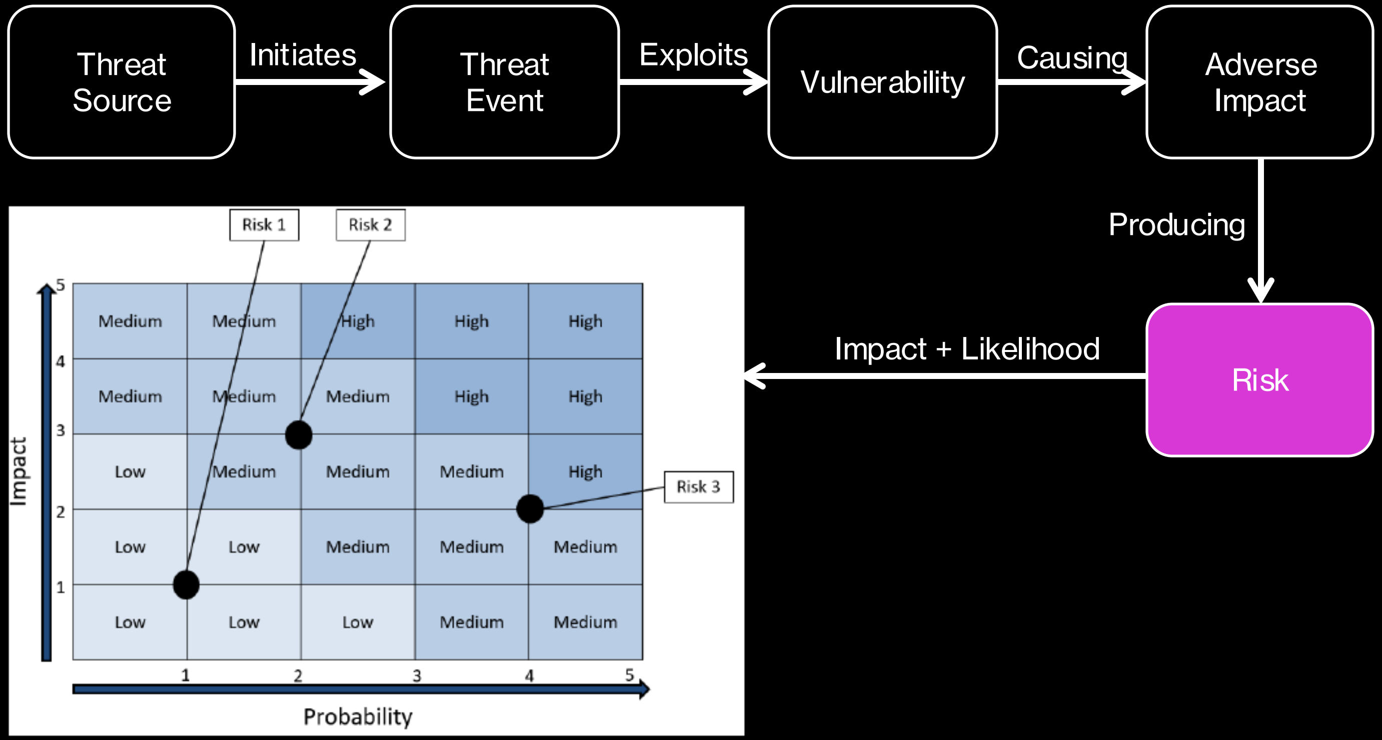
Enterprise Risk Management (ERM)

- Business risks can be categorized into preventable, strategic and external risks.
  - Preventable: employee leaking confidential information
  - Strategic: Decision to not patch IT systems to reduce cost
  - External: Bankruptcy of a cloud provider
- Cyber risks should be included in every organization's ERM



Cyber Security Risk Management

- Purpose of cyber security: protection of CIA
- Risks can be:
  - Remediated
  - Mitigated
  - Avoided
  - Transferred
  - Accepted

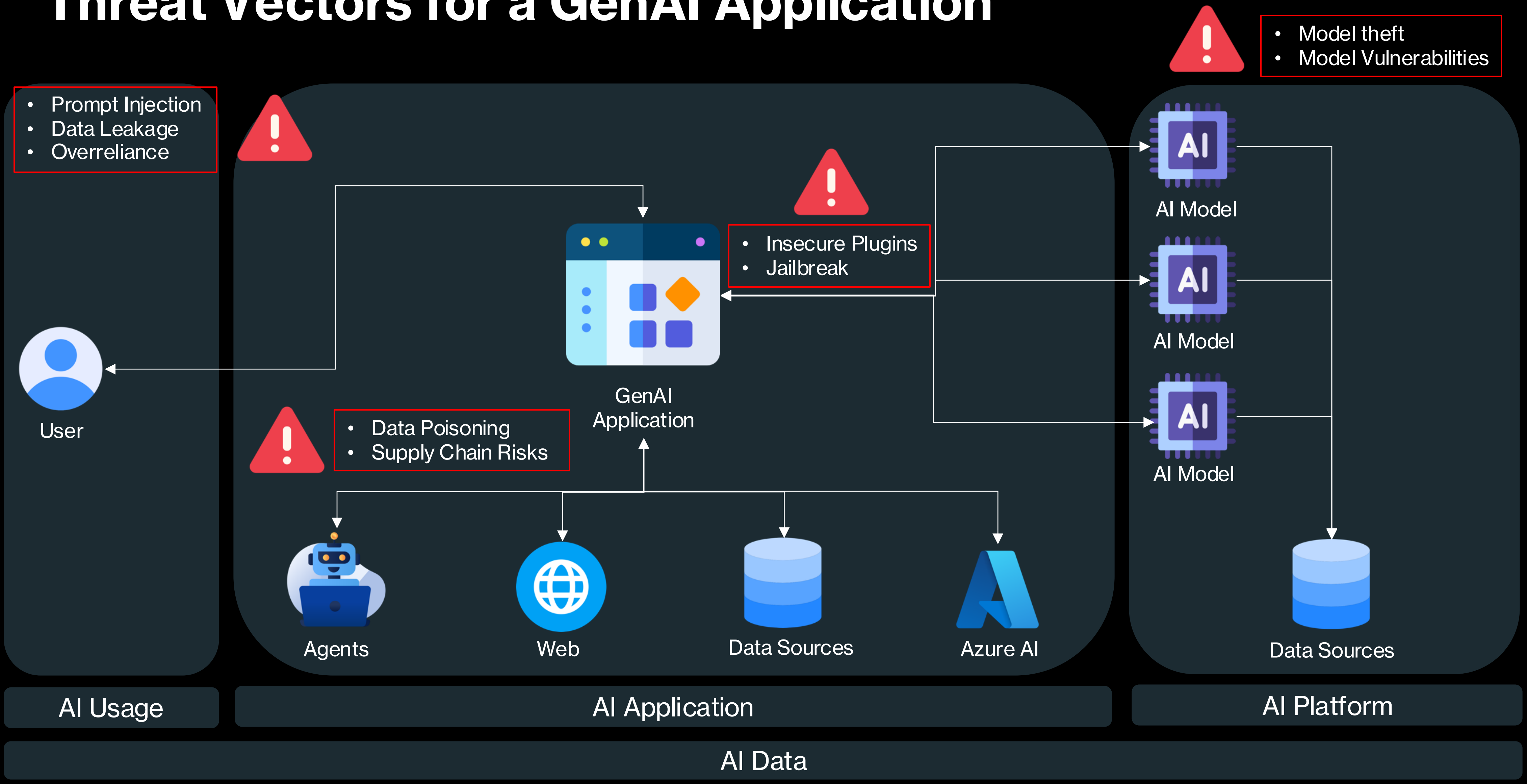


Christopher Nett

The Importance of Security in GenAI

- **Protection of Sensitive Data:** Generative AI often processes and generates sensitive information, necessitating robust cybersecurity measures to prevent data breaches and unauthorized access.
- **Maintaining System Integrity:** Cybersecurity safeguards ensure the integrity of AI systems by preventing malicious attacks that could alter AI behavior or corrupt its outputs.
- **Trust and Reliability:** Strong cybersecurity practices build trust among users and stakeholders by demonstrating a commitment to secure and reliable AI operations.
- **Compliance with Legal Standards:** Adequate cybersecurity is essential for compliance with global data protection and privacy laws, helping organizations avoid legal penalties and reputational damage.
- **Prevention of Manipulation and Abuse:** Effective cybersecurity measures prevent adversaries from manipulating AI systems to produce biased, misleading, or harmful outputs, thus protecting public safety and welfare.

Threat Vectors for a GenAI Application



Christopher Nett

What is OWASP?

- Open Worldwide Application Security Project
- OWASP Top 10
  - Web Applications
  - APIs
  - LLMs
- Open-Source Projects
  - OWASP ZAP
  - OWASP Web Security Testing guide
- Community & Events

Source: [OWASP Foundation, the Open Source Foundation for Application Security | OWASP Foundation)]

OWASP Top 10 – LLM Security Risks

1. Prompt Injection
2. Insecure Output Handling
3. Training Data Poisoning
4. Model Denial of Service
5. Supply Chain Vulnerabilities
6. Sensitive Information Disclosure
7. Insecure Plugin Design
8. Excessive Agency
9. Overreliance
10. Model Theft

Source: OWASP | Top 10 for Large Language Model Applications (llmtop10.com)

How Adversaries Leverage AI

Misinformation

- Fake images
- Fake text or news stories

Phishing

- High quality, personalized messages
- Automated conversations

Democratization of Cybercrime

- Code generation lowers technical barrier to entry
- GenAI creates exploits and evasion techniques

Impersonation

- Fake voice messages
- Fake identities

Shared Responsibility in AI

AI Usage

AI Application

AI Platform

Responsibility	IaaS (BYO Model)	PaaS (Azure AI)	SaaS (Copilot)
User Training and Accountability	Customer	Customer	Customer
Usage Policy, Admin Controls	Customer	Customer	Customer
Identity, Device, and Access Management	Customer	Customer	Shared
Data Governance	Customer	Customer	Shared
AI Plugins and Data Connections	Customer	Customer	Shared
Application Design and Implementation	Customer	Customer	Microsoft
Application Infrastructure	Customer	Shared	Microsoft
Application Safety Systems	Customer	Shared	Microsoft
Model Safety & Security Systems	Customer	Shared	Microsoft
Model Accountability	Customer	Shared	Microsoft
Model Tuning	Customer	Shared	Microsoft
Model Design and Implementation	Customer	Shared	Microsoft
Model Training Data Governance	Customer	Shared	Microsoft
AI Compute Infrastructure	Shared	Microsoft	Microsoft

Customer
Shared
Microsoft

Christopher Nett

Source: https://learn.microsoft.com/en-us/azure/security/fundamentals/shared-responsibility-ai

Microsoft Responsible AI

- Fairness
  - How might an AI system allocate opportunities, resources, or information in ways that are fair to the humans who use it?
- Reliability and Safety
  - How might the system function well for people across different use conditions and contexts, including ones it was not originally intended for?
- Privacy and Security
  - How might the system be designed to support privacy and security?
- Inclusiveness
  - How might the system be designed to be inclusive of people of all abilities?
- Transparency
  - How might people misunderstand, misuse, or incorrectly estimate the capabilities of the system?
- Accountability
  - How can we create oversight so that humans can be accountable and in control?

Source: https://www.microsoft.com/en-us/ai/principles-and-approach/

Inherent LLM risks

- Large Language Models are:
  - Imaginative but Unreliable
  - Suggestible but Literal-minded
  - Persuadable and Exploitable
  - Knowledgeable yet Impractical

Security AI Risks	Responsible AI Risks
Data Exfiltration	Ungrounded Content
Remote Code Execution	Offensive or harmful content
Model Evasion	Knowledge Recovery
AI System weight disclosure	Human impersonation
Prompt Injections	Content distribution
Generating Ransomware	

Transparency & Accountability

- **Opaque Decision-Making:** Generative AI models often operate as "black boxes," making it challenging to understand how decisions are made, leading to difficulties in accountability.
- **Auditability Issues:** Due to the complexity and proprietary nature of algorithms, auditing AI processes for transparency and fairness is often problematic.
- **Error Attribution:** When AI systems fail or produce unexpected outcomes, it can be difficult to determine the source of the error and who is responsible
- **Impact on Trust:** Lack of transparency can erode trust among users and stakeholders, who may be skeptical of using AI systems whose workings they cannot understand or scrutinize.
- **Legal and Ethical Concerns:** Transparency deficits complicate compliance with legal standards, potentially leading to breaches of ethical guidelines intended to safeguard human rights and dignity.

Regulatory Compliance

- **Evolving Legal Frameworks:** The regulatory landscape for generative AI is rapidly changing, making compliance a moving target for developers and users.
- **Global Inconsistencies:** Varying regulations across different regions can create compliance challenges for AI applications deployed internationally.
- **Data Protection Laws:** Ensuring AI systems comply with stringent data protection laws like GDPR in Europe requires significant oversight and adaptation.
- **Sector-specific Regulations:** Different industries (e.g., healthcare, finance) have specific regulatory requirements that AI systems must meet to be deployed safely and legally.
- **Reporting and Documentation:** Regulatory bodies may require detailed reporting and documentation on AI development processes and data handling practices, which can be resource-intensive.

Hallucinations

- **False Information Generation:** Generative AI can produce factually incorrect or nonsensical information, misleading users.
- **Impact on Decision-Making:** Reliance on inaccurate outputs from AI can lead to poor decision-making in critical areas like medicine or law.
- **Quality Control Challenges:** Constantly monitoring and correcting AI-generated outputs to prevent hallucinations can be resource-intensive.
- **Damage to Credibility:** Frequent inaccuracies can undermine the credibility of AI systems and the organizations that use them.
- **Training Data Limitations:** Hallucinations often stem from limitations or gaps in the training data, highlighting the need for comprehensive and high-quality datasets.

Bias & Discrimination

- **Amplification of Existing Biases:** AI systems can perpetuate and even amplify biases present in their training data, leading to unfair outcomes.
- **Discriminatory Decisions:** Biased AI can result in discriminatory practices, affecting minorities and vulnerable groups disproportionately.
- **Impact on Employment and Services:** AI-driven decisions in hiring, lending, and law enforcement can disadvantage certain demographics if not carefully monitored for bias.
- **Challenges in Bias Detection:** Identifying and mitigating biases within AI systems is complex, often requiring ongoing analysis and adjustments.
- **Legal Repercussions:** Organizations may face legal challenges if their AI applications result in biased outcomes, violating anti-discrimination laws.

Copyright Infringement and Violation of Intellectual Property

- **Unauthorized Use of Materials:** AI may generate content that inadvertently infringes on existing copyrights or uses proprietary data without authorization.
- **Legal Liabilities:** Entities using AI risk legal actions if their AI systems create or disseminate copyrighted material without proper licensing.
- **Moral Rights Issues:** AI-generated works involving art or literature can lead to violations of the original creators' moral rights, such as the right to integrity and attribution.
- **Economic Impact on Creators:** AI's ability to produce similar works rapidly and on a large scale can economically impact original creators by diluting the value of their creations.
- **Complexity in Determining Liability:** It can be difficult to determine who holds responsibility for copyright infringement when AI autonomously creates content, complicating legal proceedings.

Scenario

- You are a cyber security professional working for a huge enterprises that earns its revenue by manufacturing cars
- The company has recently decided to heavily leverage GenAI as part of their business processes
- You are tasked with creating a Governance program for GenAI

Establish a GenAI Governance Committee

- **Form the Committee**: Include cross-functional leaders from IT, legal, compliance, HR, and business units.
- **Define Roles and Responsibilities**: Clearly delineate responsibilities for oversight, ethical compliance, and technology approval.
- **Regular Meetings**: Schedule periodic meetings to review projects, policies, and compliance status.
- **Stakeholder Engagement**: Engage stakeholders in decision-making to ensure diverse perspectives.
- **Performance Metrics**: Set and monitor key performance indicators (KPIs) for governance effectiveness.

Develop Comprehensive Governance Policies and Guidelines

- **Document Policies**: Create written guidelines covering all aspects of GenAI use, including ethical standards.
- **Data Security**: Develop strict protocols for data handling, storage, and transfer.
- **Compliance Checklist**: Ensure all policies are compliant with relevant laws and industry regulations.
- **Public Transparency**: Make governance frameworks accessible to stakeholders for transparency.
- **Regular Updates**: Update policies annually or as needed to reflect technological and regulatory changes.

Implement Risk Management Practices

- **Risk Assessment Framework**: Develop a framework to identify, assess, and prioritize GenAI-related risks.
- **Vendor Assessments**: Conduct thorough risk assessments on all third-party GenAI service providers.
- **Continuous Monitoring**: Implement tools for continuous monitoring of risk factors.
- **Risk Mitigation Strategies**: Develop and implement strategies to mitigate identified risks.
- **Crisis Management**: Prepare response plans for potential GenAI-related incidents.

Standardize Review and Approval Processes

- **Structured Proposal Submission**: Create a formal process for submitting GenAI project proposals.
- **Criteria for Evaluation**: Establish clear criteria for project approval based on impact and compliance.
- **Approval Authority**: Designate specific individuals or committees responsible for project approvals.
- **Documentation of Decisions**: Maintain records of all decisions made regarding project proposals.
- **Feedback Loop**: Incorporate feedback mechanisms to refine the review process over time.

Training and User Awareness Programs

- **Customized Training Modules**: Develop role-specific training for different levels of GenAI interaction.
- **Regular Workshops**: Conduct workshops and seminars to address new developments and ethical considerations.
- **E-Learning Platforms**: Utilize e-learning platforms for scalable and consistent training delivery.
- **Certifications**: Require certifications for employees handling critical GenAI operations.
- **Feedback and Improvements**: Regularly update training content based on user feedback and technological advancements.

Adopt AI Ethics and Standards Frameworks

- **Select Frameworks**: Choose relevant international and industry-specific AI ethics frameworks.
- **Integration into Policies**: Embed these frameworks into corporate governance documents.
- **Stakeholder Training**: Train stakeholders on the principles and applications of these frameworks.
- **Regular Reviews**: Periodically review and adjust practices to remain aligned with these frameworks.
- **Ethics Audits**: Conduct audits to ensure continuous adherence to ethical standards.

Enhance Monitoring and Feedback Mechanisms

- **Implementation of Monitoring Tools**: Use software tools to track performance and user interactions with GenAI systems.
- **Real-Time Alerts**: Set up alerts for anomalies or deviations from expected behaviors.
- **User Surveys**: Regularly conduct surveys to gather user feedback on GenAI applications.
- **Analytics and Reporting**: Analyze monitoring data to generate insights for improvements.
- **Review and Action**: Review feedback and monitoring results in governance committee meetings.

Define Data and Identity Governance

- **Data Lifecycle Management**: Establish policies for data creation, storage, usage, archiving, and deletion.
- **Access Controls**: Implement strict access controls and authentication protocols.
- **Identity Verification Processes**: Utilize advanced identity verification tools.
- **Data Quality Assurance**: Regular checks to ensure data integrity and accuracy.
- **Compliance Audits**: Periodic audits to ensure data and identity management practices comply with regulations.

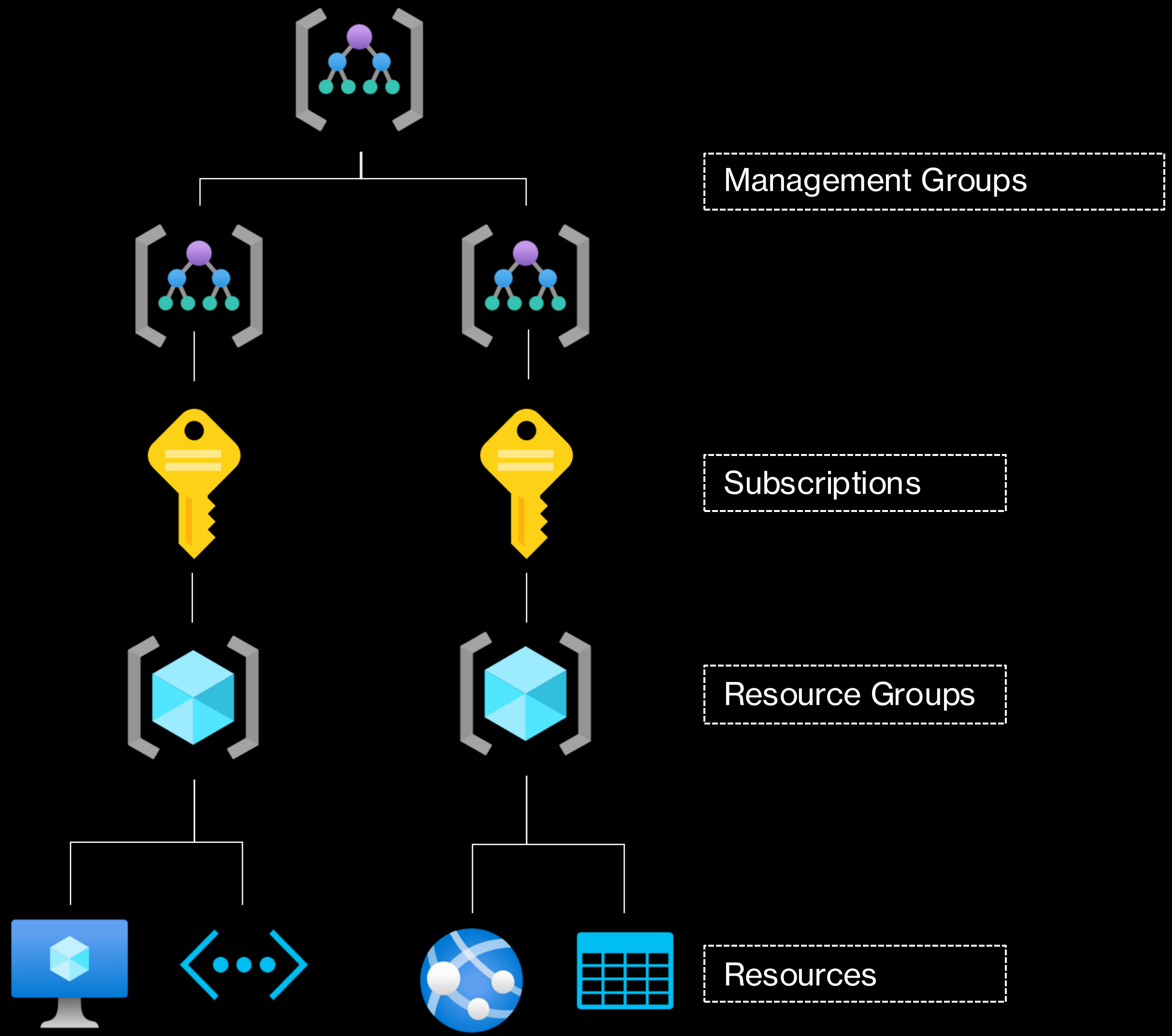
Enforce Regulatory Compliance

- **Compliance Team**: Assign a dedicated team to monitor and enforce compliance.
- **Regulatory Mapping**: Map out all applicable regulations and ensure alignment.
- **Training on Regulations**: Provide regular training on regulatory requirements.
- **Compliance Reporting**: Develop a reporting system for compliance status to the governance committee.
- **External Compliance Audits**: Engage third-party auditors to verify compliance independently.

Continuous Improvement and Adaptation

- **Feedback Mechanisms**: Establish mechanisms for continuous feedback from users and stakeholders.
- **Technology Watch**: Keep abreast of technological advancements and regulatory changes.
- **Pilot Programs**: Run pilot programs to test new policies and technologies before full-scale implementation.
- **Stakeholder Forums**: Organize forums for stakeholders to discuss challenges and propose improvements.
- **Adaptation Strategies**: Create a process for rapid adaptation of policies and technologies based on feedback and new developments.

Azure Resource Hierarchy



Christopher Nett

Azure Subscription Types

Free

- Free credits for 30 days
- Some services are free for 12 months

Student

- Free credits for 12 months
- No credit card required

Pay As You Go

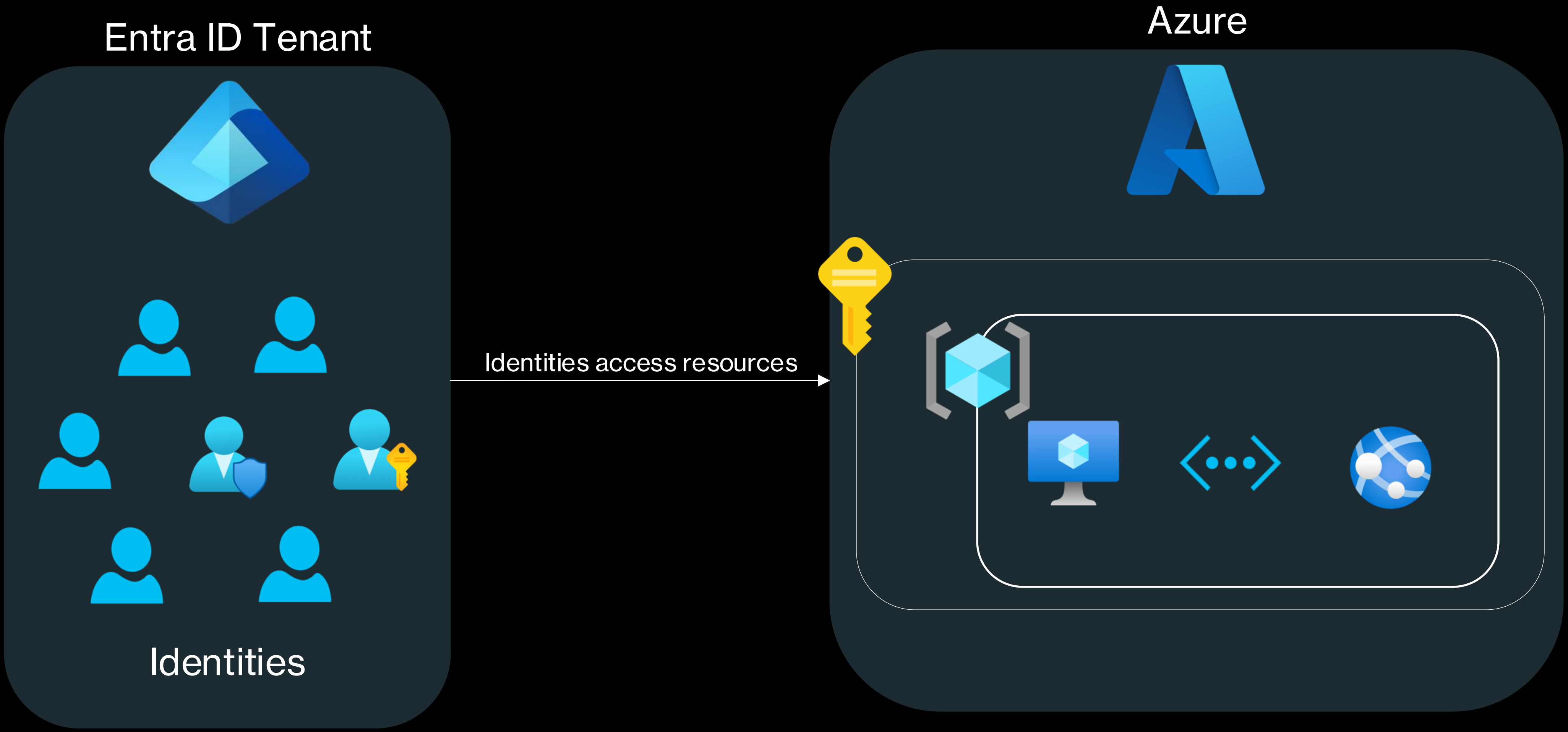
- Pay for what you use
- Credit card required

Enterprise Agreement

- One consumption agreement for all Azure services
- Various different billing models

Source: [Create Your Azure Free Account Today | Microsoft Azure]

Entra ID Tenants and Azure Subscriptions



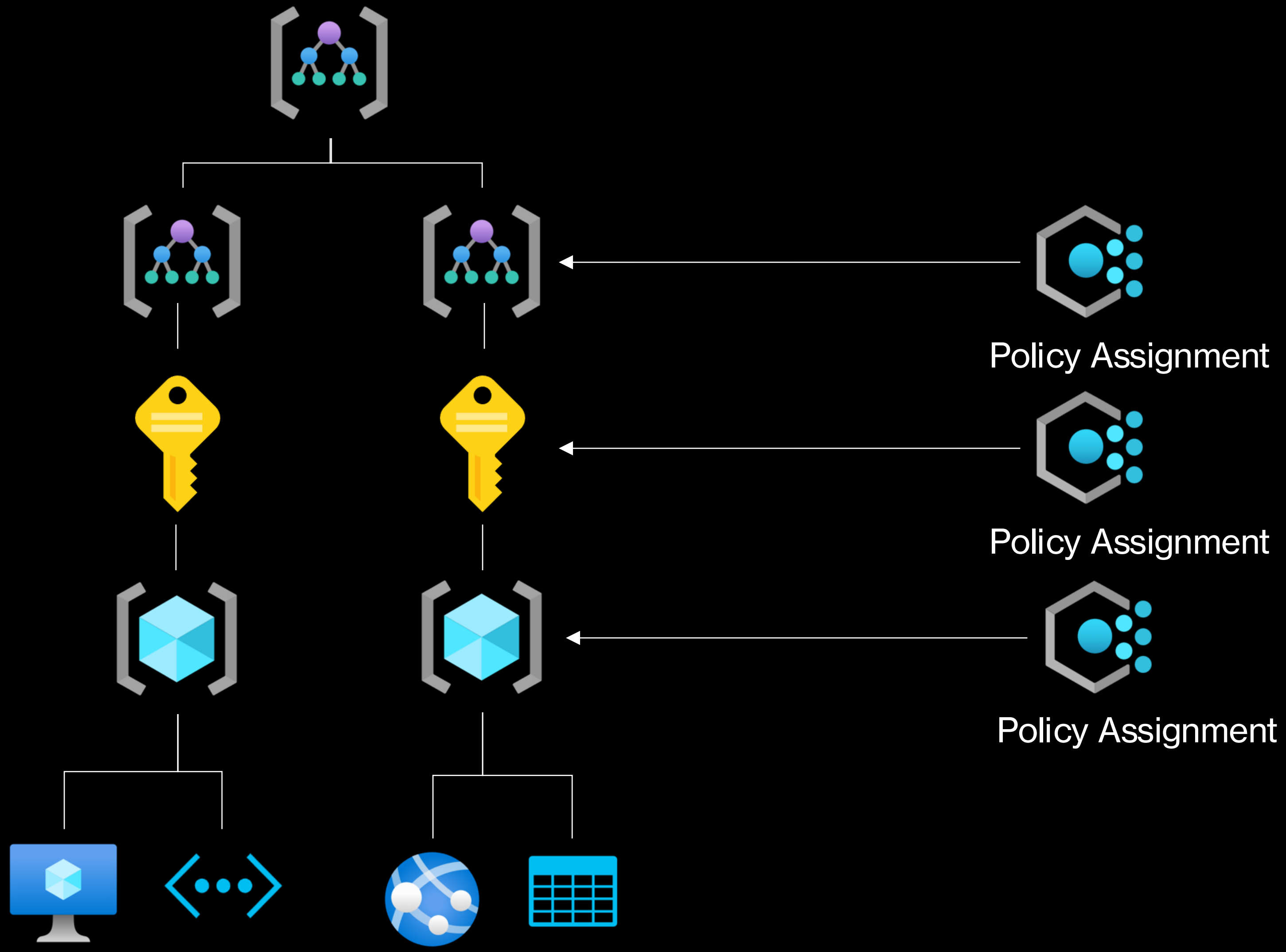
Source: [Microsoft Entra ID documentation - Microsoft Entra ID | Microsoft Learn]

Azure Policy

- An Azure Policy defines a desired configuration of an Azure resource
- Azure Policy evaluates resources and actions in Azure by comparing the properties of those resources to business rules.
- These business rules, described in JSON format, are known as policy definitions.
- To simplify management, several business rules can be grouped together to form a policy initiative (sometimes called a policySet).
- Defender for Cloud utilizes Azure Policy for all security recommendations
- Azure Policy examples in the context of security:
  - Enforce the deployment of defender for servers for all VMs
  - Audit whether an NSG is associated with a subnet
  - Deny resource creation if vulnerabilities are identified

Source: https://learn.microsoft.com/en-us/azure/governance/policy/overview

Azure Policy



Christopher Nett

Azure Policy Effects

- These effects are currently supported in a policy definition:
  - AddToNetworkGroup
  - Append
  - Audit
  - AuditIfNotExists
  - Deny
  - DenyAction
  - DeployIfNotExists
  - Disabled
  - Manual
  - Modify
  - Mutate

Source: [Understand how effects work - Azure Policy | Microsoft Learn]

Connect with me!

Get discounted courses, updates and industry insights

[My Website]

[Azure Newsletter]

[Cybersecurity Newsletter]

Social Media

LinkedIn

X

Bluesky

Threads